

1. Core Concepts

- **Cybersecurity:** Encompasses all efforts to protect computers, networks, programs, and data from unauthorized access, cyberattacks, or damage. It includes technologies, processes, and practices designed to defend systems and sensitive information.
- **Information Security (InfoSec):** Focuses specifically on protecting the confidentiality, integrity, and availability of data, regardless of the form it takes (digital or physical). InfoSec is more data-centered.
- **Information Assurance (IA):** Involves ensuring the reliability and trustworthiness of information throughout its life cycle. IA includes risk management strategies and policies to make sure data is secure, accurate, and available, particularly in mission-critical environments.

2. CIA Triad

- **Confidentiality:** Ensures sensitive information is only accessed by authorized individuals. Methods include encryption, access controls, and data classification.
- **Integrity:** Ensures data remains accurate and unaltered during storage or transfer. Techniques include checksums, hash functions, and version control.
- **Availability:** Ensures information is accessible to authorized users when needed. Backup systems, failover mechanisms, and disaster recovery plans help maintain availability.

3. Common Threats, Vulnerabilities, and Countermeasures

- **Threat:** Any potential danger that can exploit a vulnerability to cause harm (e.g., hackers, malware, phishing).
- **Vulnerability:** A flaw or weakness in a system that can be exploited by a threat (e.g., outdated software, weak passwords).
- **Countermeasure:** A control or safeguard implemented to prevent, detect, or respond to threats (e.g., firewalls, antivirus software, employee training).

4. Types of Cyberattacks and Real Cases

- **Phishing:** Fake emails or messages trick users into giving personal data like passwords or credit card numbers.
- **Ransomware:** Malware encrypts files and demands payment for decryption. Often spreads through phishing or unpatched vulnerabilities.
- **Data Breaches:** Unauthorized access to confidential data, often due to poor security practices.

5. Real-World Case Studies

- **Marriott:** Breach due to compromised employee accounts. Weak security settings like lack of MFA and logging allowed attackers to access guest data.
- **Magellan Health:** Phishing led to ransomware; attackers pretended to be clients to access systems.
- **WannaCry:** Massive ransomware outbreak via unpatched Windows systems using EternalBlue exploit. Affected hospitals and businesses worldwide.

- **COMELEC:** Government website hacked, exposing millions of voter data. Weak CMS and poor encryption caused massive data loss.
- **Colonial Pipeline:** Ransomware forced shutdown of fuel supply. Attack exploited weak authentication.
- **Bangladesh Bank:** Hackers used malware to understand transaction procedures, then tricked SWIFT system to transfer millions.
- **DNC Emails:** Hackers stole internal political emails, released them before elections to influence public opinion.
- **Yahoo!:** Forged web cookies allowed access to accounts without credentials. Company criticized for late disclosure.
- **Software AG:** High-profile ransomware attack; services disrupted and ransom demanded.
- **Twitter:** Employees were tricked via social engineering. Attackers used access to post scams on celebrity accounts.
- **PhilHealth:** Ransomware encrypted data due to expired antivirus and lack of endpoint protection. Public services disrupted.

6. Key Frameworks & Policies

- **ISO/IEC 27001:** International standard that provides guidelines on managing information security. It defines how to implement a secure system through controls.
- **SIEM:** Security Information and Event Management systems collect logs and monitor events to detect and respond to incidents.
- **Security Policies:** Rules set by organizations (e.g., SLU) to define how data should be handled, stored, and shared.

7. Information Classification and Protection

- **Classification Levels:** Public (low risk), Confidential (limited access), Secret (high impact if exposed), Top Secret (critical national or business data).
- **Protection Measures:** Encryption, MFA, access control, employee training, and regular audits based on classification.

8. Key Concepts and Controls

- **Authentication:** Verifying user identity (passwords, biometrics).
- **Authorization:** Granting permissions based on roles (e.g., admin vs. guest).
- **Identification:** Process of recognizing a user (e.g., login username).
- **Non-repudiation:** Ensures that actions or communications cannot be denied later. Often achieved using digital signatures.
- **Audit Trails:** Logs of user activity to trace security events.
- **Backup & Redundancy:** Systems in place to restore data after crashes or attacks.

9. Historical Context

- **MULTICS:** First OS to integrate security into design. Inspired UNIX.
- **Morris Worm:** First internet worm, led to formation of CERT.
- **Rand Report R-609:** First study defining the need for computer security controls.
- **Mafiaboy DDoS:** A teen caused major outages on big sites, exposing weaknesses in DDoS defenses.

10. Phishing and Social Engineering

- **Types:**
 - *Spear Phishing*: Targeted, personalized.
 - *Whaling*: Targets executives.
 - *Smishing/Vishing*: Text/voice-based.
- **Prevention**: Regular training, simulations, anti-phishing software.
- **Social Engineering**: Exploits human psychology to gain access (e.g., posing as IT staff).

11. Specialized Security Areas

- **Physical Security**: Protect physical infrastructure (e.g., locked server rooms).
- **Personnel Security**: Ensure only trusted, trained individuals have access.
- **Operations Security**: Prevent leakage of sensitive data during normal operations.
- **Network Security**: Protect LANs/WANs using firewalls, intrusion detection.
- **Application Security**: Secure software development lifecycle against threats like SQL injection.

12. Characteristics of Information

- **Accuracy**: Error-free data.
- **Relevance**: Meets user needs.
- **Timeliness**: Updated, recent.
- **Completeness**: No missing parts.
- **Consistency**: Same across platforms.
- **Clarity**: Easy to understand.
- **Accessibility**: Easy for the right people to access.
- **Verifiability**: Can be confirmed.
- **Authenticity**: Genuine and original.
- **Privacy**: Used only for its intended purpose.
- **Utility**: Useful and meaningful.
- **Possession**: Control over data, even if not read.

13. Legal and Ethical Concerns

- **Data Privacy Act (RA 10173)**: Philippine law mandating protection of personal data.
- **Ethics**: Pretexting and data sales without consent violate user trust.

14. Security Measures Classification

- **Technical**: Software-based solutions (e.g., antivirus, encryption).
- **Administrative**: Policies, awareness, response plans.
- **Physical**: Locks, guards, restricted access.

15. Threat Categories

- **Human**: Malicious insiders, user errors.
- **Technological**: System bugs, malware.
- **Physical**: Theft, disasters.
- **Environmental**: Earthquakes, floods.

- **Organizational:** Poor policies, weak procedures.
- **Supply Chain:** Infected vendor systems.

16. Defense Strategies

- **Zero Trust:** Never assume internal safety—verify all access.
- **Least Privilege:** Give users the minimal access necessary.
- **Awareness Training:** Teach staff how to recognize threats.
- **Incident Response Plan:** Steps to respond to attacks (isolate, report, contain, recover).